

nels, reliance on purloined digital certificates, ability to craft and wield potent zero-day exploits, and cutting-edge cryptography and anti-detection capabilities, we appreciate the strategic digital arsenals behind major powers' cyber warfare capabilities. Modern offensive malware developed by well-resourced state engineering teams represents a pinnacle of technical sophistication rarely appreciated publicly.

The blurred lines of cyber warfare laws

It is critical to outline the legal grey zones around state-sponsored malware before diving into technical details. Sophisticated state-developed malware exists in a complex grey area regarding cyber warfare laws and norms. While these advanced cyber capabilities outstrip historical experience, existing legal frameworks and norms around conflict provide some guidelines.

The International Tallinn Manuals represent one attempt by experts to outline how the traditional laws of armed conflict, sovereignty norms, proportionality doctrine, and civilian protection principles may apply in cyberspace. However, most nations contend that cyber operations do not constitute a true 'use of force' or 'armed attack' equivalent to conventional kinetic military actions under UN agreements. This leaves ambiguity around what types of state-sponsored malware campaigns could legally justify forceful self-defence responses. Clear evidentiary standards for attributing different operations to state actors also do not exist.

This legal fog of war enables considerable flexibility and plausible deniability for state malware operations to manoeuvre in the grey zone, pushing boundaries and exploiting gaps. The Stuxnet malware, which damaged Iranian nuclear centrifuges, represented pioneering cyber

sabotage with kinetic effects. But its unattributable nature and limited damage allowed it to sidestep armed response. Alternatively, NotPetya's indiscriminate global impact caused substantial collateral damage, potentially violating international norms around proportionality and civilian protection. But without clear attribution or legal frameworks, recourse was limited.

In essence, international law remains vague on what constitutes permitted espionage or influence versus an unlawful armed attack regarding novel cyber operations. The lack of legal clarity and attribution challenges grant considerable leeway for state malware programmers to explore boundaries of cyber warfare laws. It enables sophisticated campaigns to achieve strategic objectives while minimising provable blame and repercussions. Until complex legal issues around cyber warfare are updated and clarified, state malware will likely continue exploiting gaps and grey areas while avoiding red lines.

Detailed analysis of Stuxnet - Blueprint for physical damage

The sophisticated Stuxnet malware campaign targeting Iranian nuclear enrichment facilities represents a historic inflection point as one of the first confirmed instances of state-sponsored cyber sabotage aimed at destroying physical infrastructure. Discovered in 2010 after targeting Iranian operations for years, the Stuxnet campaign was likely a collaboration between the US and Israeli intelligence agencies, according to most expert analysis. It remains a case study of how, given sufficient resources and engineering capability, malware can be tailored to discreetly sabotage even highly sensitive isolated networks and physical equipment.

The designers of Stuxnet lever-

aged an ingenious multi-vector approach to infiltrate and compromise isolated systems at Iranian nuclear fuel enrichment facilities. Despite the Natanz facility housing critical centrifuges having no external internet connectivity, Stuxnet's developers prepared for penetrative reconnaissance and delivery of the payload through compromised third-party companies and removable media. By infiltrating the supply chain and networks of affiliated organisations, the malware operators identified vulnerabilities that allowed cracks in Natanz's physical security via unvetted USB flash drives.

Once the Stuxnet payload was deployed inside the air gapped Natanz networks, the malware demonstrated sophisticated technical acumen to disguise itself using a Windows rootkit injecting rogue code into the base operating system while intercepting and modifying API calls to cloak its presence. The Windows rootkit component leveraged stolen digital certificates to disguise Stuxnet as legitimate software. Meanwhile, the malware utilised additional zero-day local privilege escalation exploits in the Windows kernel to gain extensive administrative powers stealthily. Through this advanced infiltration and cloaking, the Stuxnet payload gained the trust and permissions necessary to reach its target—the Siemens programmable logic controllers (PLCs) running the centrifuges.

By compromising and reprogramming the PLC devices, Stuxnet's operators orchestrated a clever sabotage campaign that manipulated centrifuge spin cycles over weeks to gradually damage devices without activating obvious failure alerts. The malware essentially acted as a man-in-the-middle, intercepting communications between centrifuge sensors and monitoring systems, filtering and modifying centrifuge status data reported to deceive operators, while